00470

Sri Lanka Institute of Information Technology

B.Sc. Honours Degree in Information Technology

Final Examination
Year 3, Semester 2 (2022)

IT3070 – Information Assurance & Security

Duration: 2 Hours

November 2022

Instructions to Candidates:

- This paper has FOUR questions.
- Answer all questions in the booklet given.
- This paper is preceded by a 10-minute reading period. The supervisor will indicate when answering may commence.
- The total mark for the paper is 100.
- This paper contains SIX pages, including the cover page.
- Faculty approved calculators are allowed.

Question 1 (25 Marks)

a. Read the following security breach to answer the questions.

"Ceycorp Ltd. financial database server was penetrated by a group of anonymous hackers yesterday. The damage is still being calculated and it is believed to be in the region of $ 100,000. Cyber forensics team that was hired by the organization to investigate the incident reported that the attackers have used an HTML code via a cleverly crafted URL to penetrate the SQL Master Data Services (SQL MSD). The team has identified a major weakness in the SQL MSD that allows attackers to inject arbitrary code using 'cross site scripting' technique. The report suggests that server fails to properly sanitize user-supplied input."

i. Identify the Asset, Vulnerability and Threat in the incident. (6 Marks)

ii. Suggest a suitable countermeasure 'Ceycorp Ltd.' can implement to prevent further attacks similar to this. (2 Marks)

b. Study the following cipher text extract of a substitution cipher-based communication between two parties. Answer the given questions based on the cipher text.

"giuifg cei iprc tpnn du cei qprcni."

i. What is the complexity of a systematic brute-force approach to cryptanalyze this cipher text?

(3 Marks)

ii. If this cipher-text was generated by a simple shift-cipher, what is the complexity of a systematic brute-force approach to cryptanalyze this cipher text?

(3 Marks)

iii. Propose a less complex and a computationally feasible cryptanalysis approach for the scenario mention in (i).

(3 Marks)

Integrity Authentication

c. The three fundamental bases of information security are represented in the CIA triad. SLIIT uses multiple information platforms to conduct academic activities. Consider the given scenarios below and propose which security requirement is the highest priority for each information asset.

i. NetExam server during the mid-term examination process.
ii. File server used by lecturers to maintain final examination papers and their marking guides.
iii. Student Information Management system which contains subject grades and GPA information of a student.
iv. User password hash database maintained in the SLIIT IT service division.

(8 Marks)

Question 2 (25 Marks)

a. Information security controls can be categorized as given below.

Based on the Type of Control: Technical/Logical, Physical, Administrative
Based on the Objective of Control: Preventive, Detective, Corrective, Deterrent

Identify which type of control and the control objective for the given scenarios below.

i. Using file integrity checking software to identify if a file has been modified during the transmission.
ii. Protecting the switch/router racks by using a padlock.
iii. A warning banner for outside users, displayed in router command line interface.
iv. Conducting an awareness session for employees on password security.
v. Network isolation of a PC which was infected by a ransomware. (10 Marks)

b. 'Quantitative Risk Analysis' attempts to assign independent monetary values to system components, therefore offers direct risk cost projection. The following information is extracted from a risk evaluation done by a small enterprise.

Code Factory Pvt Ltd. is an upcoming software developing company. An initial evaluation was done to identify critical assets of the organization along with their values. One of the identified critical assets and its value is given below.

- Software Developing Platform Server - Rs. 1,500,000/=

Two of the identified risk/threat scenarios are given below.

Risk/Threat Scenario	Source	Annualized Rate of Occurrence (ARO)	Exposure Factor
Denial of Service (DOS)	CSI	0.2	20%
Ransomware Infection	Symantec	0.3	15%

i. Calculate the Annual Loss Expectancy (ALE) for DOS attack on the given critical asset? (4 Marks)

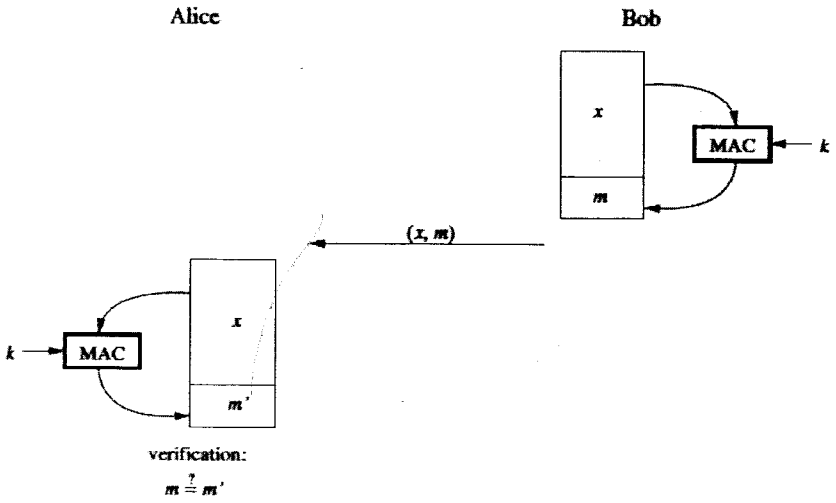
ii. Calculate the Annual Loss Expectancy (ALE) for Ransomware attack on the given critical asset? (4 Marks)

c. Using a diagram illustrate how the symmetric key distribution can be achieved using public key cryptography. (5 Marks)

d. What are the two primary principles of block ciphers according to Claude Shannon? (2 Marks)

Question 3 (25 Marks)

a. Alice and Bob are using the following method illustrated in the diagram to verify messages that are sent between them. Answer the question based on the given diagram.



i. Propose a cryptographic function which can be used to achieve the MAC function given in the diagram. (3 Marks)

ii. Evaluate the security requirements given below and indicate whether the security requirement can be achieved with the above given set up (Mention YES or NO).

1. Message Integrity
2. Message Non-Repudiation
3. Message Authentication (6 Marks)

b. Digital certificates play an important role in modern web security. John has obtained a digital certificate from a certificate authority. During the HTTPS connection establishment John has presented his certificate to Sally. Which key belonging to which user can be verified using the presented certificate? (4 Marks)

c. Access control is the prevention of unauthorized use of a resource, including the prevention of use of a resource in an unauthorized manner. Refer the access matrix given below and answer the given questions.

	File A	File B	File C
Alice	RW	RW	RW
Bob			
Carol	RW		
David			RW

(P.T.O)

i. Create the access control list (ACL) for File B.

(3 Marks)

ii. Create the capability ticker for Bob.

(3 Marks)

iii. Propose the most suitable access control policy for the given scenarios below.

1. Military information system for security personnel
2. Online learning platform for Students, Lecturers & Administrators
3. UNIX & Windows operating system with multiple users

(6 Marks)

Question 4 (25 Marks)

a. The process of verifying an identity claimed by or for a system entity.

i. Name a mechanism which can be used for the given means of authenticating a user's identity.

1. Something the individual knows
2. Something the individual possesses
3. Something the individual does
4. Something the individual is

(8 Marks)

ii. Remote user authentication raises additional security threats such as eavesdropping and replay attack. The countermeasure generally relies on challenge-response protocol. Propose a challenge response protocol to counter threats mentioned above. (Hint: A diagram can be used for explanation)

(6 Marks)

b. "Firewall can be describes as an electronic 'Checkpoint' between a (relatively) protected network/device and a (relatively) untrusted network." Refer the firewall table below and answer the questions.

No.	Protocol	Source IP	Destination IP	Dest. Port	Action
1	TCP	10.1.1.1	20.1.1.1	80	Accept
2	TCP	10.1.1.2	20.1.1.1	80	Deny
3	TCP	10.1.1.0/24	20.1.1.1	80	Deny
4	TCP	10.1.1.3	20.1.1.1	80	Accept
5	TCP	10.2.2.0/24	20.2.2.5	80	Deny
6	TCP	10.2.2.5	20.2.2.0/24	80	Deny
7	TCP	10.3.3.0/24	20.3.3.9	80	Accept
8	TCP	10.3.3.9	20.3.3.0/24	80	Deny
9	IP	0.0.0.0/0	0.0.0.0/0	0-65535	Deny

(P.T.O)

i. What is the purpose of placing rule number 3 after rule number 1.

(3 Marks)

ii. What is the standard name given to rule number 9.

(2 Marks)

iii. 10.1.1.254 is the IP address of the firewall itself. In order to protect the firewall itself, suggest a suitable rule and recommend where to place it in the rule list.

(3 Marks)

c. Differentiate the terms 'Disaster Recovery' & 'Business Continuity' with respect to information security.

(3 Marks)

--End-of-Question-Paper--